

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE CODE: CSA51 **COURSE NAME:** Cryptography and Network Security

COURSE OUTCOME COVERED

CO4: *Implement best security practices for IP, email, and web service using PGP, S/MIME for enhancing email Security.CO (BL3, BL6)*

Assessment Tool Weightage: 20%

QUESTIONS: 5

TOTAL MARKS: 25

Annexure A

Industry Problem-Solving Task

Code of Conduct:

*I RITHISH KUMAR D / 192565089 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.*

Signature of the student: RITHISH KUMAR D

Department: CSE-CS

Date: 17-08-2026

ANSWER SHEET - ASSESSMENT TOOL 2

Industry Problem-Solving Task | CSA51 - Cryptography and Network Security

Q1. IPsec ESP Overhead and Network Optimization in Enterprise VPN

Given: Payload = 1200 B, IP header = 20 B → original packet = 1220 B. ESP header = 8 B, ESP trailer+padding = 16 B, ESP auth (ICV) = 16 B. Packet rate = 15,000 pkt/s.

A. Total packet size after ESP encapsulation

ESP overhead = 8 + 16 + 16 = 40 bytes.

Total packet size = 1220 + 40 = **1260 bytes**.

(Note: since the scenario is tunnel mode, an additional new outer IP header of 20 bytes is typically also added in a real deployment, giving 1280 bytes; the 1260-byte figure above uses only the ESP-specific overhead values explicitly supplied in the problem.)

B. Percentage overhead due to IPsec

Overhead % = $(40 / 1220) \times 100 = 3.28\%$

C. Additional bandwidth consumed per second

Extra bytes/sec = $40 \times 15,000 = 600,000$ bytes/s = **4.8 Mbps** of additional bandwidth purely from ESP overhead.

D. Security vs. performance trade-off and optimization

Stronger authentication/encryption (larger ICV, AES-256 vs AES-128) increases per-packet overhead and CPU cost, directly raising latency and bandwidth consumption at 15,000 pkt/s scale. Optimization strategies: (1) prefer **transport mode** over tunnel mode between data centers that do not need topology hiding, to avoid the extra outer IP header; (2) use **AES-GCM (combined-mode)** instead of separate encryption + HMAC, which removes the need for a distinct 16-byte auth trailer while giving the same security guarantee; (3) enable **IP-payload compression (IPComp)** before encryption on compressible traffic; (4) use **hardware crypto offload (AES-NI / IPsec accelerator cards)** so overhead affects bandwidth but not CPU-bound latency; (5) tune the **rekey interval** so security association renegotiation does not add jitter during peak load.

Q2. AH and ESP Combination with MTU Constraints in Financial Networks

Given: Payload (excl. headers) = 1480 B, base IP header = 20 B → original IP packet = 1500 B. AH adds 24 B, ESP adds 32 B (transport mode). MTU = 1518 B.

A. Final packet size after AH + ESP

Final size = 1500 + 24 (AH) + 32 (ESP) = **1556 bytes**.

B. Will fragmentation occur?

Since 1556 B > MTU (1518 B), the packet exceeds the MTU by 38 bytes, so **fragmentation will occur**. Each fragment needs its own 20-byte IP header, so splitting the 1556-byte packet into pieces that individually fit within 1518 bytes requires **2 fragments** (e.g. approx. 1518 B + 58 B, well within the limit).

C. Performance/latency implications for high-frequency trading (HFT)

HFT systems are extremely latency-sensitive (microsecond-scale). Fragmentation forces the receiver to buffer and reassemble packets, adds an extra transmission + processing round for the second fragment, increases the probability of packet loss (loss of any single fragment invalidates the whole datagram), and can trigger retransmission delays that are unacceptable for trading systems where even sub-millisecond delay affects order execution and arbitrage opportunity.

D. Recommended optimized configuration

(1) Use **ESP alone with combined authenticated encryption (AES-GCM)** instead of AH+ESP, eliminating AH's 24-byte overhead while still providing integrity and confidentiality - final size drops to roughly 1500 + 32 = 1532 B, close to the MTU boundary. (2) Enable **Path MTU Discovery / jumbo frames (MTU 9000)** on the trading network so the 1556-byte secured packet fits in a single frame. (3) Where jumbo frames are not possible end-to-end, apply **TCP MSS clamping** so that the unencrypted payload size is pre-adjusted to avoid post-encryption fragmentation. (4) Consider **selective protection** - AH only for order-acknowledgement control messages (integrity-critical, latency-tolerant) and full ESP for bulk market-data feeds.

Q3. Scalability and Key Management in Large-Scale IPsec Deployment

Given: 8,000 concurrent SAs. Per SA: 256-bit (32 B) encryption key + 160-bit (20 B) integrity key + 80 B metadata = 132 B/SA. Rekeying every 30 min doubles active SAs temporarily.

A. Memory required during peak rekeying

Normal memory = $8,000 \times 132 \text{ B} = 1,056,000 \text{ B} \approx 1.03 \text{ MB}$.

During rekeying, active SAs double to 16,000, so peak memory = $16,000 \times 132 \text{ B} = \mathbf{2,112,000 \text{ bytes} \approx 2.06 \text{ MB}}$.

B. Key generation workload per hour

Rekeying occurs every 30 minutes $\rightarrow$ 2 cycles/hour. Each cycle regenerates a key-set (encryption + integrity key) for all 8,000 active SAs.

SA key-sets generated/hour = $8,000 \times 2 = \mathbf{16,000}$, i.e. **32,000 individual keys/hour** (16,000 encryption + 16,000 integrity keys).

C. Scalability challenges at 12,000 clients

Peak memory becomes $12,000 \times 2 \times 132 \text{ B} = 3,168,000 \text{ B} \approx 3.02 \text{ MB}$, and key generation workload rises to 24,000 SA key-sets/hour (48,000 keys/hour) - a proportional (50%) increase. The real bottleneck is rarely raw memory; it is the **IKE negotiation CPU cost** (Diffie-Hellman exponentiations), **SPI allocation contention**, and **synchronized rekey storms** where many SAs expire together and flood the key-management server simultaneously, causing latency spikes.

D. Optimized key-management techniques

(1) **Jittered/staggered rekey timers** so SAs do not all expire simultaneously, smoothing CPU load. (2) **ECC-based key exchange (ECDH, e.g. Curve25519)** instead of classic Diffie-Hellman - equivalent security at far lower CPU cost and smaller key-exchange messages, directly reducing the IKE workload measured above. (3) **Hierarchical / group key management (e.g. GDOI, GKMP)** for large clusters of similar clients, sharing a group key structure instead of 8,000-12,000 fully independent pairwise SAs. (4) **Hardware Security Module (HSM) offload** for key generation/storage to remove CPU/memory pressure from the main IKE daemon. Together these can reduce rekeying-related CPU load by 40-60% at the 12,000-client scale.

Q4. Performance Analysis of Secure Email using PGP and S/MIME

Given: Attachment = 5 MB (5,242,880 B). PGP overhead = 600 B/email. S/MIME overhead = 1.2 KB (1,228.8 B)/email. Volume = 2,000 emails/hour.

A. Total data transmitted per hour

Metric	PGP	S/MIME
Overhead / email	600 B	1,228.8 B
Total size / email	5,243,480 B	5,244,108.8 B
Total data / hour (2,000 emails)	10,486,960,000 B $\approx$ 9.77 GB	10,488,217,600 B $\approx$ 9.77 GB

B. Bandwidth and processing overhead comparison

S/MIME consumes 628.8 more bytes per email than PGP (1,228.8 vs 600 B), i.e. about 1,257,600 bytes ($\approx$ 1.2 MB) more per hour across 2,000 emails - negligible ($<0.02\%$) next to the 5 MB attachment itself. The bigger difference is **processing overhead**: S/MIME requires X.509 certificate parsing, chain-of-trust validation and revocation checking (CRL/OCSP lookups) for every message, which is more CPU- and latency-costly per email than PGP's simpler key-ID/web-of-trust lookup, even though PGP's on-wire overhead is smaller.

C. Impact on email server performance and latency

At 2,000 emails/hour ($\approx$ 0.56 emails/sec), bandwidth impact from either scheme is negligible for a modern enterprise link. The dominant cost is CPU: S/MIME's certificate-chain and revocation checks add measurable per-message latency and can become a bottleneck under burst load (e.g. morning peak) unless OCSP responses are cached, whereas PGP's overhead stays largely constant regardless of load.

D. Recommendation for large-scale deployment

For a corporate environment, **S/MIME** is generally preferable at scale because it integrates with the organization's existing PKI/Active-Directory certificate infrastructure, enabling centralized issuance, automated renewal and revocation - important for compliance and audit. To control its processing overhead: enable **OCSP-stapling / CRL caching**, and use **hardware-accelerated TLS/crypto** on the mail gateway. Retain **PGP** as an option for communication with external partners who do not share the corporate CA (decentralized trust), giving a hybrid deployment that balances the two approaches' strengths.

Q5. Spam Detection System Evaluation and Optimization

Given: 100,000 emails/day, 45% spam (45,000), 55% ham (55,000). FPR = 3%, FNR = 6%. Cost of misclassification = Rs. 5/email.

A. Confusion matrix (per day)

False Negatives (spam missed) = $45,000 \times 6\% = 2,700$

True Positives (spam caught) = $45,000 - 2,700 = 42,300$

False Positives (ham blocked) = $55,000 \times 3\% = 1,650$

True Negatives (ham delivered) = $55,000 - 1,650 = 53,350$

	Predicted Spam	Predicted Ham
Actual Spam (45,000)	TP = 42,300	FN = 2,700
Actual Ham (55,000)	FP = 1,650	TN = 53,350

B. Total daily financial loss

Misclassified emails = FP + FN = $1,650 + 2,700 = 4,350$

Daily loss = $4,350 \times \text{Rs. } 5 = \text{Rs. } 21,750$ per day

C. Evaluation using performance metrics

Precision = $TP / (TP + FP) = 42,300 / 43,950 = 96.25\%$

Recall (Sensitivity) = $TP / (TP + FN) = 42,300 / 45,000 = 94.00\%$

Accuracy = $(TP + TN) / 100,000 = 95,650 / 100,000 = 95.65\%$

F1-score = $2PR / (P + R) = 95.11\%$

The filter is reasonably strong ($F1 > 95\%$), but a 6% FNR means roughly 1 in 17 spam emails still reaches the inbox, and a 3% FPR means legitimate business emails are occasionally lost - a serious risk for a financial/corporate setting where a missed client email has real cost.

D. Optimization strategies and expected improvement

(1) **Threshold tuning** - shifting the classification threshold trades FPR against FNR depending on which error is costlier to the business. (2) **Hybrid detection** - combine the current statistical filter with rule-based checks (SPF/DKIM/DMARC, sender reputation, blacklists) to catch cases the ML model misses. (3) **Ensemble/ML upgrade** - replacing a single classifier with a boosted ensemble (e.g. Random Forest + Naive Bayes voting) typically cuts error rates by 30-50%. Illustrative target: reducing FPR to 1.5% and FNR to 3% gives FP = 825, FN = 1,350, total misclassified = 2,175, daily loss = Rs. 10,875 - a saving of **Rs. 10,875/day** ($\approx 50\%$) over the current system.

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Industry Problem	20%	Comprehensive understanding of real-world problem and constraints	Good understanding with minor gaps in requirements	Basic understanding; some requirements unclear	Poor understanding ; misinterprets problem context
Application of Engineering Concepts	25%	Applies advanced and relevant concepts effectively to solve the problem	Applies appropriate concepts with minor errors	Limited application of concepts	Incorrect or no application of concepts
Solution Design	25%	Innovative, practical, and feasible solution aligned with industry standards	Logical and feasible solution with minor gaps	Basic solution with limited feasibility	Unclear or impractical solution
Use of Tools	15%	Effective use of modern tools, technologies, and real data	Appropriate use of tools with correct implementation	Limited or inconsistent use of tools	Minimal or incorrect use of tools
Analysis	10%	Thorough analysis with validated results and performance evaluation	Good analysis with reasonable validation	Basic analysis with limited validation	Poor or no analysis
Professionalism	5%	Highly professional, well-documented, and clearly presented work	Good documentation and presentation	Basic documentation with some gaps	Poor documentation and presentation